Storm-3358 ARTEX Abuse: A Detection Engineering Analysis of Agentic AI-Driven Intrusions Against the Financial Sector

Abstract

In October 2026, the financially motivated threat actor Storm-3358 began targeting organisations in the financial sector using the agentic AI offensive framework ARTEX. Microsoft Threat Intelligence tracks Storm-3358 as a Cambodia-based intrusion cluster that primarily targets financial organisations in Southeast Asia, alongside a smaller number of large financial organisations globally. The actor used ARTEX in combination with conventional automated tools to scan internet-connected systems, exploit security flaws including anonymous file upload and server-side request forgery, and install open-source remote access trojans including WISP, vshell, and AdaptixC2. ARTEX agents leveraged common utilities such as netcat and curl to download these RATs to compromised systems, and used web shells for persistence on compromised web servers. This working paper translates the behavioural patterns described in the Microsoft Security Blog publication into concrete detection opportunities, each tied to a Sigma rule, and identifies the classes of activity that remain invisible to defenders. The analysis covers network connections to published IOC infrastructure, curl-based file downloads, shell execution spawned by PHP processes, and executable permission modifications on downloaded files. It also addresses the limitations of IP-based detection given the actor's use of proxies and VPNs, and the challenge of distinguishing agentic AI tooling from legitimate administrative automation.

What happened

In October 2026, the financially motivated threat actor Storm-3358 began targeting organisations in the financial sector using the agentic AI offensive framework ARTEX. The threat actor that Microsoft Threat Intelligence tracks as Storm-3358 is a Cambodia-based intrusion cluster that primarily targets financial organisations in Southeast Asia, in addition to a smaller number of large financial organisations globally.

Microsoft observed Storm-3358 use ARTEX in combination with conventional automated tools to scan systems connected to the public internet, exploit security flaws including anonymous file upload and server-side request forgery (SSRF), and install open-source remote access trojans (RATs). Storm-3358 has used the WISP, vshell, and AdaptixC2 RATs for persistence and lateral movement. Microsoft observed ARTEX agents using utilities like netcat and curl to download these RATs to compromised systems.

In recent ARTEX-related attacks, threat actors used ARTEX agents to scan and exploit vulnerabilities in web applications, use web shells for persistence on compromised web servers, compromise credentials from public sources and compromised systems, and use compromised cloud identities for persistence and data exfiltration. ARTEX agents can also perform brute-force password attacks, password spraying, API enumeration and abuse, and database dumping. The source states that agentic tools like ARTEX can leverage compromised credentials and systems at machine speed to move laterally, escalate privileges, and exfiltrate data.

The source describes ARTEX as using existing penetration testing tools by default, including Nmap, curl, wget, Python HTTP clients, Norma SDK WebFetch, and headless Chromium through Playwright, among others. These tools may send network traffic with distinctive characteristics, such as default user agent strings. The source notes that while blocking network traffic with these characteristics will not stop an attack by an AI agent, which will quickly change them, identifying

them can alert defenders to the activity.

Microsoft published indicators of compromise comprising eight IP addresses. Three addresses, 199.19.95[.]66, 199.19.95[.]67, and 199.19.95[.]68, are identified as WISP C2 nodes, first seen on 2026-11-02 and active as of 2026-11-06. Three further addresses, 91.92.240[.]238, 85.11.168[.]45, and 178.16.54[.]129, are identified as ARTEX servers, first seen on 2026-11-04, 2026-11-04, and 2026-10-19 respectively. The address 85.11.167[.]52 is identified as a C2 server, first seen on 2026-11-04. The address 31.77.229[.]35 is identified as an ARTEX server, first seen on 2026-10-28. All indicators were active as of 2026-11-06.

The source contains a discrepancy between the Sentinel hunting query and the IOC table. The Sentinel query lists the IP address 178.15.54.129, while the IOC table lists 178.16.54.129. This discrepancy is present in the source itself and should be resolved before building IP-based rules. Both variants may warrant inclusion in detection logic.

The source explicitly warns that threat actors regularly use proxies and virtual private networks (VPNs) to change the source IP address of malicious traffic and bypass static detections. Microsoft states it is providing the IOCs to help defenders detect related activity despite this limitation.

Microsoft also describes defensive measures including honeypots, decoys, tarpits, and fake wins. The source states that honeypots and decoy surfaces such as Microsoft Sentinel Deception give the agent attractive but worthless targets to pursue, that tarpits consume the agent's time and budget, and that fake wins present convincing evidence that the agent's objective is complete, which can cause it to stop on a false success. In Microsoft's testing, these controls helped reduce the attack traffic reaching real assets and produced high-confidence, attribution-quality signal.

The source references two additional Microsoft blog posts for further context on ARTEX evolution: one titled "AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise" and another titled "Threat actors use agentic AI tooling to find and abuse exposed secrets." The latter post describes Microsoft Threat Intelligence observing threat actors using ARTEX to search GitHub for OAuth application secrets, which can be used to compromise the associated OAuth application and perform authenticated actions in the application's tenant.

Detection opportunities

The source provides several behavioural patterns that defenders can watch for. Each detection opportunity below is tied to a Sigma rule file in the detection pack.

Network connections to Storm-3358 ARTEX or WISP C2 infrastructure (01-network-connection-to-storm-3358-artex-or-wisp-c2.yml). The source publishes eight IP addresses tied to WISP C2 nodes, ARTEX servers, and a C2 server. Connections to these addresses are a direct consequence of C2 communication with Storm-3358 infrastructure. The Sentinel hunting query provided in the source checks IP addresses across data sources in the past 30 days using the ASIM network session parser, looking for sessions where the destination IP matches the published IOC list. The query summarises first seen, last seen, and event count by source IP, destination IP, destination domain, device, event product, and event vendor. This detection maps to MITRE ATT&CK technique T1071 (Application Layer Protocol). Defenders should implement this rule using firewall, NSG, or similar network session logs parsed through ASIM. Given the discrepancy between the Sentinel query IP (178.15.54.129) and the IOC table IP (178.16.54.129), both variants should be included in the rule to ensure coverage regardless of which is correct. The source cautions that IP-based detections are short-lived because threat actors regularly rotate source IP addresses

through proxies and VPNs, so this rule should not be the sole detection method. Nevertheless, the published IPs were active as of 2026-11-06 and provide immediate hunting value.

Curl downloading files from remote URLs (02-curl-downloading-file-from-remote-url.yml). The source describes ARTEX agents using curl to download RATs to compromised systems. Microsoft published an advanced hunting query for Defender XDR that looks for new files being downloaded using curl. The query establishes a seven-day baseline of known files downloaded by curl, then identifies curl downloads in the most recent day that do not match the baseline. The query operates across both DeviceNetworkEvents and SecurityEvent (EventID 4688, Process Creation) data sources, extracting URLs and IP addresses from curl command lines using regular expressions. The source explicitly notes that curl has legitimate uses, so files and hosts should be reviewed to identify potentially malicious activity. This detection maps to MITRE ATT&CK technique T1105 (Ingress Tool Transfer). The hunting query is classified as a HUNT rather than an ALERT, meaning it requires baseline tuning and human review to manage false positives. The source lists curl among the default tools ARTEX uses, alongside Nmap, wget, Python HTTP clients, Norma SDK WebFetch, and headless Chromium through Playwright. Because these tools are common in administrative and development contexts, the detection requires environmental baselining to identify anomalous curl downloads rather than blocking all curl activity.

Shell execution spawned by a PHP process (03-shell-execution-spawned-by-php-process.yml). The source states that threat actors used web shells for persistence on compromised web servers. Shell execution spawned by PHP is a direct consequence of web shell activity, where a PHP web shell executes operating system commands. Microsoft Defender for Endpoint includes an alert titled "Suspicious shell execution from PHP application" in its Execution tactic coverage. This detection maps to MITRE ATT&CK technique T1505.003 (Server Software Component: Web Shell). The source lists this alert among several that "may trigger on unrelated activity," and states that customers should investigate to determine if the alert is related to the activity outlined in the blog. Defenders should treat this as an ALERT-level detection, meaning it warrants immediate investigation when triggered. The detection is most relevant on systems running PHP web applications, particularly those exposed to the public internet, which aligns with the source's description of Storm-3358 scanning systems connected to the public internet and exploiting vulnerabilities in web applications.

Execute permission added to a file in common download locations (04-execute-permission-added-to-file-in-common-downloa.yml). The source describes RATs being downloaded and launched on compromised systems. On Linux, adding execute permissions to a downloaded binary is a necessary step before it can be run. Microsoft Defender for Endpoint includes an alert titled "Executable permission added to file or directory" in its Defense Evasion tactic coverage. This detection maps to MITRE ATT&CK technique T1222.002 (File and Directory Permissions Modification: Linux and Mac File and Directory Permissions Modification). The source describes ARTEX agents using curl and netcat to download RATs, after which the binaries would need execute permissions to be launched. Defenders should focus this detection on files in common download or temporary directories, as legitimate software installation typically uses package managers rather than manual chmod operations on downloaded files. The source lists this alert among those that may trigger on unrelated activity, so investigation is required to determine relevance.

Additional detection signals from the source. Beyond the four Sigma rules in this pack, the source describes several other behavioural signals that defenders could develop into detections. Microsoft Defender for Endpoint includes an alert for "Suspicious port scan activity" under the

Discovery tactic, mapping to T1046 (Network Service Discovery). The source states that ARTEX agents scan systems connected to the public internet, making port scan detection a direct consequence of the scanning phase. A "Possible reverse shell" alert under the Command and Control tactic maps to T1059.004 (Command and Scripting Interpreter: Unix Shell), and is a consequence of RAT persistence mechanisms like WISP, vshell, and AdaptixC2. A "Suspicious cron job creation" alert under the Persistence tactic maps to T1053.003 (Scheduled Task/Job: Cron), reflecting the persistence goal of RAT installation. The source also describes high-velocity, varied web requests from a single source as a behavioural signal of agentic AI scanning. Agentic AI frameworks scanning a target send a wide variety of requests in a brief time and retry variations on the same technique or move on to next-stage actions at machine speed. This maps to T1595.003 (Active Scanning: Wordlist Scanning) and would be detectable through web server logs or WAF logs. The source notes that default user agent strings from tools like Nmap, curl, wget, Python HTTP clients, and headless Chromium may be distinctive, but warns that an AI agent will quickly change them, making user agent-based detections fragile.

What cannot be detected

Several classes of activity in this campaign are invisible to defenders or indistinguishable from legitimate behaviour, regardless of the detection rules deployed.

The internal decision-making of the ARTEX agent is entirely invisible. Defenders see only the tool execution the agent produces, not the reasoning, planning, or task selection that precedes it. The source describes ARTEX as an agentic framework that can scan, exploit, install RATs, compromise credentials, perform brute-force attacks, password spraying, API enumeration, database dumping, and exfiltrate data. From the defender's vantage, each of these manifests as a discrete tool execution or network request, but the orchestration layer that decides which action to take next, and in what sequence, produces no directly observable telemetry. The source describes this as machine-speed acceleration of all stages of the attack chain, meaning the compressed timeline between scanning, exploitation, and persistence may itself be a detection signal, but the agent's internal state is not exposed.

Traffic between the ARTEX agent and its ARTEX server over TLS is not inspectable without additional controls such as TLS interception. The source identifies several IP addresses as ARTEX servers, but the content of communications between compromised systems and these servers is encrypted. Defenders can observe that a connection occurred, its timing, volume, and destination, but cannot inspect the commands, tasking, or data flowing over that channel without middleware that terminates and inspects TLS, which many environments do not deploy universally.

Valid credentials used successfully by the agent after compromise are indistinguishable from legitimate authentication unless session context or behavioural analytics flag the source. The source describes ARTEX agents compromising credentials from public sources and compromised systems, and using compromised cloud identities for persistence and data exfiltration. Once an attacker possesses valid credentials, authentication events appear normal in identity logs. Microsoft Entra ID Protection generates Verified threat actor IP risk detections when sign-in activity originates from known threat actor infrastructure, including agentic frameworks like ARTEX, delivered at high risk. However, if the agent authenticates from an IP address that has not been flagged as malicious, or routes through a residential proxy or VPN that has not been associated with threat activity, the authentication appears legitimate. The source explicitly warns that threat actors regularly use proxies and VPNs to change the source IP address of malicious traffic, making IP-based

detection transient and unreliable as a sole detection method.

The distinction between ARTEX agent activity and legitimate penetration testing or administrative automation is fundamentally difficult at the process and network level. The source states that ARTEX by default uses Nmap, curl, wget, Python HTTP clients, Norma SDK WebFetch, and headless Chromium through Playwright. All of these tools have legitimate administrative, development, and security testing uses. A defender observing curl downloading a file from a remote URL, or Nmap scanning a network range, cannot definitively determine whether the activity originates from an ARTEX agent or a human administrator performing the same task. The source notes that default user agent strings may be distinctive but that an AI agent will quickly change them, removing even this weak signal. The machine-speed velocity of agentic activity may be a distinguishing characteristic, as the source describes agents sending a wide variety of requests in a brief time and retrying variations at machine speed, but this requires behavioural baselining and velocity-based analytics rather than simple signature matching.

The source does not publish file hashes for the RAT families used (WISP, vshell, AdaptixC2). These are described as open-source RATs, which means signatures or hash-based detection may be available from other sources, but the blog post itself does not provide file indicators. Defenders relying solely on the source for indicators are limited to the eight published IP addresses and the behavioural patterns described.

Limitations

This working paper is a machine draft produced for a human editor. It is based solely on the source text and the checked assessment. No telemetry was collected, no testing environment was used, and the Sigma rules referenced have not been validated against real attack data or legitimate activity in a production environment.

The source is a single vendor blog post published on November 6, 2026. It describes activity observed beginning October 2026 but does not provide a complete technical breakdown of every action taken by Storm-3358 or every ARTEX capability exercised. The detection opportunities described are derived from the behavioural patterns explicitly mentioned in the source, but the source may not enumerate all techniques used by the actor. Detections built solely from the source text may have gaps where the source is silent.

The hunting query for curl-based downloads is designed to identify new files downloaded by curl relative to a seven-day baseline. This approach assumes that curl download behaviour is consistent enough within an environment to establish a meaningful baseline, and that malicious downloads will involve files not previously seen. In environments where curl is used heavily and variably for legitimate purposes, this query may produce significant false positives. The source acknowledges this, stating that curl has legitimate uses and that files and hosts should be reviewed to identify potentially malicious activity.

The IP-based detection rule relies on indicators that the source explicitly states are transient. Threat actors regularly use proxies and VPNs to change source IP addresses, and the published IPs may be replaced or abandoned. The source notes that all published IPs were active as of 2026-11-06, but their longevity beyond that date is uncertain. The discrepancy between the Sentinel query IP (178.15.54.129) and the IOC table IP (178.16.54.129) further complicates IP-based detection, as it is unclear from the source which address is correct.

The Defender for Endpoint alerts referenced in the source are listed as potentially triggering on

unrelated activity. The source states that customers should investigate to determine if alerts are related to the activity outlined in the blog. This means the alerts have known false positive rates that the source does not quantify. The Sigma rules in this pack that correspond to these alerts inherit this limitation.

The source does not provide file hashes, file names, file paths, or command line arguments for the RATs downloaded by ARTEX agents. Figure 1 of the source is described as showing example commands that ARTEX agents used to download RATs, but the actual command text is not included in the source text provided for this analysis. Detection rules that might rely on specific command line patterns or file names are therefore limited to the general behavioural patterns described rather than specific string matches.

No part of this analysis has been peer reviewed. The Sigma rules have not been tested against attack simulations or legitimate traffic samples. The detection logic is derived from the source's description of attacker behaviour and the published hunting queries, but its effectiveness in a real environment depends on factors including telemetry coverage, log retention, baseline noise levels, and the specific tools and configurations in use at each organisation.

References

https://www.microsoft.com/en-us/security/blog/2026/11/06/artex-abuse-expands-as-cybercriminals-target-financial-sector/